

Privileged Access Management (PAM)

Lean implements a layered, zero-trust Privileged Access Management (PAM) approach to control, monitor, and audit all privileged access to production systems in the KSA region

1. Identity & MFA Controls

2. Privileged Access & Session Management

Teleport Controls

Break-Glass Access

3. Cloud Infrastructure Administrative Controls

OCI KSA

4. Zero-Trust Network Access

5. Secrets Management

1Password

HashiCorp Vault

6. Privileged Access Governance (Joiner / Mover / Leaver)

Joiners

Movers

Leavers

7. Privileged Access Reviews

8. Monitoring, Logging & Audit

9. Key Principles Enforced

10. Summary

1. Identity & MFA Controls

- **JumpCloud** is the central identity provider for employees and enforces MFA for all administrative accounts.
- **GitHub** is used for Teleport authorization:
 - GitHub team membership and privileges are managed using **Terraform** in the **Infrastructure-as-Code repository** (PR-based approval, audit trail).
 - All members of the Lean GitHub organization must have **2FA enabled**.

- Only members of approved GitHub teams can authenticate to Teleport for production access.
- **OCI KSA access controls:**
 - Console access requires **JumpCloud SSO/SAML** authentication.
 - **MFA is mandatory** for all privileged users.
 - Access is restricted to **trusted IP ranges** to prevent unauthorized network paths.
 - Only a small, approved DevOps group can access OCI

Identity path for privileged access:

JumpCloud (MFA) → GitHub team (2FA) → Teleport role → Production resources

JumpCloud (MFA + SSO/SAML + trusted IPs) → OCI console (limited scope)

2. Privileged Access & Session Management

Lean uses **Teleport** as the central platform for privileged sessions:

Teleport Controls

- Certificate-based, short-lived credentials (no static passwords).
- **Database Access:** PostgreSQL and MongoDB managed via Teleport Database Access with full query/session logs.
- **Kubernetes Access:** Restricted to DevOps; kubectl commands and API interactions are recorded.
- **Session Recording:** All SSH, database shell, and Kubernetes sessions are captured
- **RBAC:** Teleport roles enforce least privilege for DevOps.

Break-Glass Access

- All break-glass (BG) cases are logged in **Jira**.
- Teleport session logs and **Elasticsearch** logs provide full traceability.
- Access is:

- Time-limited
- Requires approval
- Fully audited and reviewed after use

3. Cloud Infrastructure Administrative Controls

OCI KSA

- MFA enforced for console access.
- Privileged roles restricted to DevOps only.
- All audit logs forwarded to SIEM.

4. Zero-Trust Network Access

Twingate provides identity-based, least-privilege access to internal production services:

- No VPN or flat-network access.
- Access is routed only to resources a user is authorized for.
- Device posture verification and identity checks enforced.

5. Secrets Management

Lean uses a dual-tier secrets-governance model:

1Password

- Is used for secure storage of human-managed secrets across multiple teams. Access is organized into **separate vaults per function** (Engineering, DevOps, Security, etc.), ensuring least-privilege and segregation of duties. Each vault has role-based access control, and all users accessing privileged or sensitive vaults must use **MFA**. No sensitive credentials are stored locally or shared outside their assigned vaults.

HashiCorp Vault

- Used for machine and workload secrets, including API tokens, service credentials, and database connection secrets.
- Enforces encryption, controlled policy-based access, and credential rotation.
- Only DevOps administrators have access to Vault's management interface.

6. Privileged Access Governance (Joiner / Mover / Leaver)

Lean maintains a controlled JML process with clear separation of duties across IT, Security, and DevOps. All privileged access is identity-driven and auditable.

Joiners

- The **IT team** creates the employee identity in **JumpCloud** and enforces MFA during onboarding.
- **Twingate group membership is mapped to JumpCloud groups**, ensuring identity-based, automated assignment of network access based on role.
- The **DevOps team** provisions privileged system access (e.g., GitHub team membership, Teleport roles, cloud IAM) through **Terraform Pull Requests**, ensuring approval and traceability.

Movers

- Changes in job responsibilities trigger updates to:
 - JumpCloud groups (managed by IT)
 - Twingate access (automatically updated via JumpCloud group mapping)
 - GitHub teams, Teleport roles, and cloud IAM roles (managed by DevOps via IaC)
- Previous privileges are removed as part of the PR workflow to maintain least privilege.

Leavers

- The **IT team** disables the JumpCloud identity upon HR offboarding notification, immediately removing Twingate access through group mapping.

- The **DevOps team** removes the user from GitHub teams, Teleport, cloud IAM roles, and any other privileged systems through Terraform PRs and immediate manual revocation where required.

All JML actions are traceable via:

- GitHub PR history
- Jira workflow events
- JumpCloud audit logs

7. Privileged Access Reviews

Lean performs periodic reviews (monthly/quarterly) of:

- GitHub team membership
- Teleport roles
- Cloud IAM roles (OCI)
- Vault and 1Password access
- Service accounts with elevated permissions

Findings are documented, and unnecessary privileges are removed.

8. Monitoring, Logging & Audit

A full audit trail of privileged activity is maintained:

- Teleport session recordings (SSH, DB, kubectl)
- GitHub events (team membership changes, 2FA compliance)
- JumpCloud identity logs (MFA status, lifecycle actions)
- OCI audit logs (IAM changes, API activity)
- Twingate access logs
- Break-glass events stored in Jira/Teleport and Elasticsearch

9. Key Principles Enforced

Lean enforces several core privileged-access principles to ensure the security and integrity of the KSA production environment:

- **Restricted production access:** Only a small, dedicated DevOps team has administrative access to production. Developers and other staff do not have any production access.
- **Compensating controls for small-team structure:** While DevOps engineers perform both operational changes and monitoring due to team size, strong technical controls (MFA, short-lived certificates, RBAC, IaC approval workflows, SIEM monitoring) compensate for the lack of strict functional separation.
- **Least privilege:** Access is granted only to the minimum set of resources required for each role. Privileged roles and permissions are regularly reviewed and updated through IaC and JML processes.
- **Short-lived, certificate-based authentication:** Teleport provides ephemeral certificates for SSH, Kubernetes, and database access, eliminating long-lived credentials and reducing attack surface.
- **MFA enforcement:** All privileged paths (Teleport, Twingate, cloud consoles, JumpCloud) require MFA to authenticate.
- **Infrastructure-as-Code governance:** Privileged access (GitHub teams, Teleport roles, cloud IAM changes) is managed through Terraform and Pull Request approvals, ensuring transparency, traceability, and dual-control.
- **Comprehensive audit logging:** All privileged sessions, identity events, IAM changes, and break-glass activities are logged to SIEM for real-time monitoring, alerting, and post-event investigation.
- **No local storage of secrets:** All sensitive credentials are stored in managed vaults (1Password for human secrets, HashiCorp Vault for machine/workload secrets), ensuring centralized control, MFA protection, and auditability.

10. Summary

Lean enforces strict PAM controls through identity verification, MFA, least-privilege authorization, session recording, zero-trust network boundaries, and comprehensive audit logging. Privileged access is fully governed, time-bound,

certificate-based, and monitored across all layers of the KSA production environment.